Agent Tool Contract Drift

A Reapproval Vocabulary and Evaluation Harness for Model-Invoked Tools

Technical White Paper
Prepared for public scrutiny

Jason M. Lovell
Independent Researcher
jason@jasonlovell.ai
ORCID: 0009-0001-6300-9155

July 2026

Abstract

Agent clients discover tools through descriptors that name capabilities, describe their use, declare schemas and security schemes, and provide execution or presentation hints. A descriptor change can therefore alter the approval decision even when an ordinary API diff remains compatible.

Agent Tool Contract Drift is a pre-review research artifact for that narrower problem. It contributes an implementation-neutral reapproval vocabulary, two explicitly named corpora, provenance controls, carrier comparisons, and blinded evaluation scaffolding. The public package corpus contains 53 project-authored synthetic descriptor pairs, of which 22 are held for review and 31 are quiet; the reference policy emits 25 findings. Its separate manifest identity retains 28 project-authored synthetic regression cases from the private corpus byte-for-byte and adds 25 newly authored synthetic quiet controls. It is not a subset of the private corpus and contains 0 source-derived descriptor bytes. The private canonical corpus retains 65 pairs, 26 holds, 39 quiet cases, and 30 findings: 37 public-source-derived records plus those 28 synthetic records. The public corpus is the self-contained public-package reproduction target; the private result is disclosed but not shipped as public evidence.

Configured carrier parity is a main design check. A configured-policy path and an oasdiff adapter match the private corpus 65/65 because they share or map the same policy predicates. That result is substitute pressure, not independent native-tool validation. It demotes the standalone linter from the contribution claim: the durable artifact is the vocabulary, corpus discipline, provenance boundary, reviewer harness, and carrier decision framework. There are no external reviewer responses or independently scored sealed cases. This is not a validated benchmark, not a security scanner, not a standard, and not production evidence.

Status of This Document

This is a pre-review technical white paper prepared for public scrutiny. It is not peer reviewed. The evidence snapshot records 0 external reviewer responses, 0 scored sealed cases, no independent gold-label artifact, and no live GitHub code-scanning upload evidence. It should be read as reproducible policy and evaluation infrastructure, not as validation.

All views and conclusions are solely the author's own. No employer, client, vendor, standards body, protocol maintainer, or upstream project has endorsed this draft. The paper is not legal advice, security advice, or a production security assessment.

The private coordinator surface contains the 65-pair corpus, study assignment and custody material, unscored answer-key scaffolding, and source-provenance records. The public distribution is designed to contain the separate manifest-bound 53-pair all-synthetic corpus, policy and reference implementation, worked examples, public reports, and release metadata.

Contents

Status of This Document **2**

1 Introduction **4**

2 Descriptor drift as an approval-review surface **4**

3 Contribution and non-contribution **5**

4 Policy model **6**

5 Corpus and method **7**
5.1 Worked example 7
5.2 Corpus identities and composition 8
5.3 Evidence provenance and redistribution 9

6 Results **9**
6.1 Current local findings 9
6.2 Reserved external results 10

7 Substitute and carrier analysis **10**

8 Reviewer study protocol **11**

9 Sealed evaluation boundary **13**

10 Implementation and reproducibility **13**

11 Threats to validity **14**

12 Release posture **15**

13 Conclusion **15**

Disclosure **16**

A Claim boundary checklist **16**

B Primary local artifacts **16**

1 Introduction

Ordinary API review asks whether a change breaks a caller. Tool-descriptor review has an additional question: did the change alter what a model may select, what a user is told, or the authority implied by the next invocation? A compatible parameter change can still require renewed approval.

The Model Context Protocol (MCP) defines tool descriptors with names, titles, descriptions, input and output schemas, icons, execution metadata, annotations, and change notifications [1, 2]. The OpenAI Apps SDK adds security schemes and presentation metadata such as resource and output-template references [4, 5]. These fields affect discovery, planning, consent, and rendering. They are not merely comments.

The annotation defaults matter. In the 2025-11-25 MCP schema, an omitted `readOnlyHint` means false, an omitted `destructiveHint` means true, an omitted `idempotentHint` means false, and an omitted `openWorldHint` means true [2]. Explicitly writing a default is a restatement, not a new escalation. Explicitly declaring `readOnlyHint: true` or `destructiveHint: false` can be a safer claim. The reference implementation normalizes those defaults before comparing descriptors and treats annotations as untrusted hints rather than proof of runtime behavior [3].

That combination creates the research problem for Agent Tool Contract Drift:

> If a trusted tool descriptor changes from read-only summary to scoped write, send, delete, broader authorization, open-ended input, sensitive presentation behavior, or newly instruction-laden description text, what evidence should force reapproval before the changed tool is accepted?

Agent Tool Contract Drift studies that question through a policy and harness. It does not execute tools, verify authorization, inspect live MCP servers, or certify that a tool is safe. It asks whether a portable vocabulary can turn a static before/after descriptor diff into a reviewable reapproval decision.

2 Descriptor drift as an approval-review surface

The phrase "tool contract" is used here in a narrow sense. It is the contract exposed to an agent client and reviewer through descriptor metadata. The runtime implementation may be unchanged, and the HTTP or JSON schema may remain backwards-compatible, while the model-facing approval story changes materially.

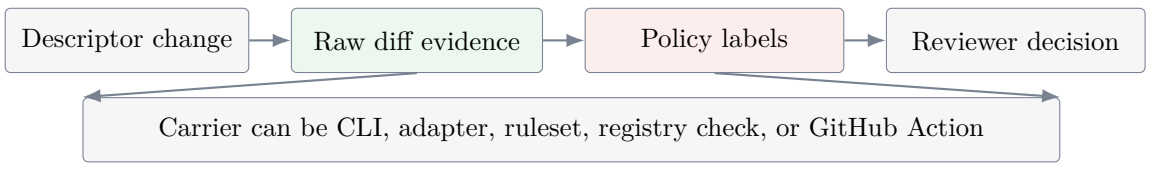


Figure 1: Descriptor drift as an approval-review problem. Agent Tool Contract Drift does not replace raw diffs or existing governance tools. It defines review labels that can be carried by several implementation surfaces.

This framing puts existing carriers in scope rather than treating them as baselines to defeat. OpenAPI defines a mature description format for HTTP APIs [7]. oasdiff compares OpenAPI documents and emits machine-readable change evidence [12]. Spectral applies configurable rules and custom functions to JSON, YAML, and OpenAPI documents [13]. SARIF 2.1.0 is a standard exchange format for static-analysis results, and GitHub code scanning can ingest a supported subset [11, 10]. A reapproval policy could live in any of these surfaces.

Recent MCP security research studies nearby failure modes. Wang et al. evaluate poisoned tool metadata against real MCP servers in MCPTox, while Yang et al. model attacks across MCP clients, transports, and servers in MCPSecBench [22, 23]. Agent Tool Contract Drift is not a poisoning benchmark. It examines the preceding governance question: what descriptor change should force a human to reconsider approval?

Temporal tool-definition attacks are direct prior art. Song et al. include rug pulls among four MCP attack categories and report a user study in which participants struggled to identify malicious servers [24]. Bhatt, Narajala, and Habler's Enhanced Tool Definition Interface uses identity, immutable versioned definitions, signatures, and explicit permissions to resist tool squatting and rug pulls [25]. Beurer-Kellner and Fischer's MCP-Scan pins tool descriptions and hashes them to detect post-approval changes while also scanning for poisoning and cross-origin escalation [26]. The Microsoft-hosted Agent Governance Toolkit's draft MCP Security Gateway specification is especially close implementation prior art: it fingerprints descriptions and schemas, raises rug-pull alerts when fingerprints change, and defines baseline schema-drift categories and severity rules [27]. It is a draft toolkit specification, not an MCP standard or an independent evaluation. Together, these systems rule out descriptor-drift detection itself as a novelty claim. Agent Tool Contract Drift addresses the narrower human-governance layer between "the descriptor changed" and "this change needs renewed approval."

3 Contribution and non-contribution

The package's primary contribution is the reapproval vocabulary. Three supporting contributions make it inspectable and testable.

1. **Reapproval vocabulary.** Ten implementation-neutral labels for descriptor changes that warrant review or cannot be classified soundly without manual analysis.
2. **Corpus and provenance boundary.** Separate, manifest-bound identities for a 53-pair all-synthetic public corpus and a 65-pair source-checkout-only private corpus. The public corpus retains the private corpus's 28 project-authored synthetic records byte-for-byte, adds 25 new synthetic controls, is not a private-corpus subset, and has 0 source-derived descriptor bytes.
3. **Evaluation scaffolding.** A worked example, carrier comparisons, blinded review packets, two-rater-plus-resolver adjudication, frozen-output custody checks, and a 30-day feasibility gate for a randomized exploratory pilot.

4. **Reference engineering.** A dependency-light Python implementation, capture normalization for MCP 2025-11-25 and 2025-06-18, Markdown/JSON/SARIF output, a GitHub Action wrapper, and an oasdiff adapter.

The package supplies no validation evidence. It is not a validated benchmark, security scanner, MCP or Apps SDK conformance test, or evidence that a tool is safe or unsafe. It does not prove reviewer lift, maintainer demand, production readiness, or that generic tools cannot implement the policy.

The Python linter is a reference implementation, not the contribution boundary. If reviewers prefer a Spectral ruleset, oasdiff adapter, registry check, or compact research note, that is a valid outcome.

4 Policy model

Agent Tool Contract Drift consumes a before/after descriptor pair. Each descriptor is a normalized view of tool-facing metadata:

- tool name and description;
- input schema and output schema;
- annotations such as read-only, destructive, idempotent, and open-world hints;
- auth or security-scheme scopes;
- output template or presentation-resource references;
- tool-set membership.

The label set is small by design. Nine labels express a concrete review reason. The tenth, `schema_containment_unresolved`, is a fail-closed manual-review outcome for schema changes the implementation cannot compare soundly.

Label	Review meaning	Boundary
`readonly_to_destructive`	A previously read-like tool now appears able to write, mutate, delete, send, or execute.	String and annotation heuristic, not runtime proof.
`destructive_hint_escalation`	Destructive semantics were introduced.	Client hints remain hints.
`destructive_hint_downgrade`	Destructive hints were removed while risky language remains.	Detects stale or inconsistent metadata.
`description_injection_drift`	Tool text gained agent instructions, hidden-instruction language, or exfiltration cues.	Metadata review signal, not exploit proof.
`auth_scope_expansion`	Security scopes or provider scopes broadened.	Static metadata only.

`closed_world_to_open_world_input`	A bounded input surface became more open.	JSON Schema comparison, not formal proof.
`schema_containment_unresolved`	A schema change uses references or combiners whose containment cannot be established by the supported rules.	Manual review; no weakening claim is made.
`sensitive_output_template_drift`	Presentation-boundary metadata changed around sensitive output.	Descriptor-level evidence, not proof that a UI renders sensitive data.
`sensitive_output_schema_expansion`	Output schema gained sensitive-looking fields.	Field-name heuristic.
`risky_tool_added`	A new risky-looking tool entered the tool set.	Name and description heuristic.

The policy is meant to travel. The same decisions can be expressed through a Python runner, a configured OpenAPI extension ruleset, an oasdiff adapter, or another carrier that preserves the review semantics.

The implementation classifies only schema comparisons it can justify. Simple monotone changes, such as removing an enum restriction or opening `additionalProperties`, can be classified. Branch counts alone do not establish containment for `oneOf` or `anyOf`; adding `allOf` does not by itself prove weakening; and unresolved `\$ref` targets prevent a sound local comparison. Those cases produce manual review instead of a confident direction-of-change label. This follows the JSON Schema model in which applicators compose constraints rather than behaving as a simple field list [8, 9].

5 Corpus and method

The evidence base is curated, not random or population-representative. It is a regression and review harness. Two corpus names prevent source checkouts and installed packages from silently making different claims.

5.1 Worked example

The synthetic fixture `fixture-001-readonly-to-destructive` shows the intended review flow. The tool name and input schema remain stable. Four descriptor fields change.

Field	Before	After
Description	"Search approved documentation."	"Search or delete matching documentation records when cleanup is requested."
`readOnlyHint`	`true`	`false`
`destructiveHint`	`false`	`true`
Authorization scopes	`docs.read`	`docs.read`, `docs.delete`

Table 2: Worked descriptor change. The unchanged input shape would not explain the new delete authority.

An ordinary diff exposes the changed text, booleans, and added scope. The policy adds three candidate labels: `readonly_to_destructive`, `destructive_hint_escalation`, and `auth_scope_expansion`. Both the configured-policy carrier and the oasdiff adapter return those labels because they reuse or map the same predicates. Their agreement is a portability check, not independent confirmation. The review decision is a hold: the new delete behavior and scope require renewed approval. The labels explain why; they do not prove what the implementation will do.

5.2 Corpus identities and composition

Corpus	Pairs	Hold / quiet	Findings and boundary
`public-reproduction-53`	53	22 / 31	25 findings; 53 project-authored synthetic records: 28 private-corpus synthetic records retained byte-for-byte plus 25 new quiet controls; 0 source-derived descriptor bytes.
`private-canonical-65`	65	26 / 39	30 findings; 28 synthetic records plus 37 public-source-derived records; source-checkout-only and not shipped.

Table 3: Named, separate corpus identities. The public corpus retains 28 project-authored synthetic private-corpus records and adds 25 new controls; it is not a private-corpus subset. Counts are local regression evidence, not benchmark scores, independent validation, or prevalence estimates.

Split in private corpus	Pairs	Hold	Quiet	Findings
Synthetic proof and adversarial cases	28	22	6	25
Public commit-backed records	37	4	33	5
Total	65	26	39	30

Table 4: Exact private-corpus composition. The 53-pair public corpus retains the 28 synthetic rows, adds 25 new controls, and includes none of the 37 public-source-derived rows.

5.3 Evidence provenance and redistribution

The private provenance layer records 37 public commit-backed fixtures, 16 retained source-full static descriptor replays, 9 hash-only source-full demotions, and 0 current-fixture full descriptor replays. These coordinator records support traceability, not a claim of source-exact reconstruction or runtime MCP capture. They are not inputs to the public reproduction corpus.

The public corpus is a separate manifest-bound all-synthetic artifact. It retains the 28 project-authored synthetic private-corpus records byte-for-byte and adds 25 new synthetic quiet controls; because of those additions, it is not a subset of the private corpus. Its content-manifest SHA-256 is `330c174becdc c98efee8ef438e389ea4e13af767c89f0e851a2528497e2f3e2e`; its finding-set SHA-256 is `b92ed6d812 3c3b66f73a0e2acfd04c0fd05b13df0d39b8e5ba7171978347e74f`; the 28 retained full records hash to `d83bbd5d362c1b26cc7be0f2ef0704ac7813a13a78efb74a1c0b2e62044cd345`; the retained descriptor pairs hash to `1050809458224ce7468354bf484a9ad8c2526187db510679f2945c063370783d`; and the 25 new quiet-control records hash to `e55a8b9e49c0418745cce5f55010044052aabba5d55031082101 bbcf79559f11`. This construction makes the public package self-contained, but it does not provide real-world source grounding or external validation; no external reproduction has yet been recorded. A future release can add real descriptor evidence only as a separately frozen corpus with defensible provenance and no tuning on later held-out scoring cases.

6 Results

6.1 Current local findings

The primary public result is 25 finding instances on the 53-pair all-synthetic public corpus: 22 hold fixtures and 31 quiet/control fixtures. The private canonical run emits 30 finding instances on 65 pairs: 26 holds and 39 quiet/control fixtures. These are exact regression counts, not precision, recall, false-positive, false-negative, prevalence, or validation estimates. The expected labels were curated during development and have not been independently adjudicated.

Correcting MCP annotation defaults removed a substantive false signal. Across 12 annotation-addition regression fixture records containing 16 tool changes, 7 changes explicitly restate protocol defaults and 9 make a safer explicit declaration. None is an actual escalation after normalization, and all 12 fixtures are now quiet. This negative result matters more than preserving the old count: a release gate that contradicts protocol defaults is not rescued by a green regression suite.

The public SARIF file carries the 25 public-corpus findings. A 35-check local ingestion surrogate passes, but the release snapshot contains no live upload observation and the local metadata does not claim a project URL. The SARIF driver therefore omits `informationUri` unless a real HTTPS project URL is configured. The field is optional in the standard [11].

Evidence tier	Current status
Public regression evidence	Separate manifest-bound 53-pair all-synthetic package corpus: 28 retained project-authored synthetic private-corpus records plus 25 new controls, 22 hold fixtures and 31 quiet/control fixtures, 25 finding instances, 0 source-derived descriptor bytes.
Private regression evidence	Separate 65-pair source-checkout-only corpus, 26 hold fixtures and 39 quiet/control fixtures, 30 finding instances.
Public grounding	53 project-authored synthetic records; no external reproduction or real-source corpus evidence.
Private source replay	16 retained source-full static descriptor replays, 9 hash-only source-full demotions, and 0 current-fixture full descriptor replays.
Reviewer evidence	0 external reviewer responses.
Sealed evaluation	10 sampled unlabelled sealed candidates and 0 scored sealed cases.
Code scanning	Local SARIF preflight has 0 failed checks, with no live GitHub code-scanning upload evidence.

Table 5: Evidence ladder. The strongest local gates are engineering gates, not research validation.

6.2 Reserved external results

No external-result table is populated in this draft. The declared reviewer endpoints are gold-label accuracy, false-positive rate, false-negative rate, decision movement, and qualitative carrier preference. The scorer refuses promotion when the frozen pre-outreach gold artifact or custody hashes are absent. External reproductions, new descriptor pairs, live SARIF rendering, adjudicator agreement, and maintainer carrier judgments also remain unobserved. Later versions must report recruitment failure or partial completion as such; they must not convert either into validation.

7 Substitute and carrier analysis

Carrier parity is a design check, not a contest. The release reports record 65/65 configured-rule matches and 65/65 real oasdiff adapter matches while sharing or mapping the reference predicates. Both carriers also reproduce the 53-case public corpus when that corpus is selected explicitly. This rejects the claim that Agent Tool Contract Drift needs a standalone linter because existing governance surfaces cannot carry the policy. It does not show that native Spectral or oasdiff independently implements the semantics, and it does not justify zero false-positive or false-negative claims.

Carrier or substitute	Current result	Interpretation
Unconfigured raw diff	Shows changed fields.	Necessary context, but it does not supply a reapproval vocabulary.
Configured policy path	65/65 private-corpus match.	Policy portability; predicates are shared with the reference implementation.
oasdiff v1.23.0 adapter	65/65 private-corpus match.	Real oasdiff transport plus a project-specific mapper; not an independent comparator.
Spectral custom-function design	Three of ten labels sketched; no packaged parity run.	Feasible carrier, currently incomplete and demoted.
Exact descriptor hash	Flags every change.	Useful freshness signal, too blunt without an allowlist.
Risk-field hash plus allowlist	Can encode the current decisions.	Loses label meaning and inherits author choices.
GitHub SARIF	Local structural preflight passes.	Reporting carrier only; not vulnerability evidence.

Table 6: Carrier analysis. The work should survive only if reviewers want the semantic policy or workflow beyond raw configured outputs.

With implementation form no longer the differentiator, the remaining question is whether reviewers value the policy. The project uses explicit decision rules:

Decision	Evidence threshold
Promote	Independent reviewers reproduce the need for the vocabulary, gold-scored labels improve declared review endpoints without unacceptable control noise, and at least one maintainer or practitioner prefers a reusable carrier.
Pivot	Reviewers want the vocabulary or corpus but prefer oasdiff, Spectral, registry, or policy-only delivery. The standalone CLI becomes a reference executable.
Demote	Reviewers find the framing useful but the evidence remains descriptive, recruitment fails, or the public corpus cannot gain source-backed positive cases. Publish only a bounded research note and harness.
Kill	Independent adjudication finds the labels unsound, raw/configured views are sufficient, provenance cannot support the retained claims, or the work cannot be reproduced from the public artifact.

Table 7: Promote, pivot, demote, and kill criteria. Standalone-tool novelty is already demoted by substitute parity.

8 Reviewer study protocol

The first external step is a simpler blinded bakeoff with three reviewers who are independent of the author, adjudicators, and compared-carrier maintainers. It asks whether raw diffs, neutral generic

labels, or the reapproval vocabulary change the review decision and which carrier should own the policy. This path is descriptive expert review, not an efficacy trial.

The six-slot, four-arm design remains available only as a randomized exploratory pilot. Its arms show raw diff, generic labels, semantic labels, or intentionally noisy/placebo labels. Configured-policy and oasdiff outputs are coordinator diagnostics, not randomized arms. The design is too small and too dependent on specialized recruitment to be described as an RCT, statistically powered efficacy study, or proof of reviewer lift. Software-engineering pilot guidance calls for explicit objectives, procedures, selection, measures, and go/no-go decisions [17]. The CONSORT pilot extension is used only as a feasibility-reporting analogy; this is not a clinical study and does not commit to a later definitive trial [16]. The protocol also follows applicable software-engineering experiment and reporting expectations [14, 15].

Eligibility requires current professional experience with MCP/tool maintenance, platform approval or authorization engineering, security/release governance, or empirical software-engineering research. The screener records role evidence, prior exposure to the artifact, conflicts, and ability to protect employer-confidential information. Quotas cover the first three practitioner roles. Alternates replace withdrawals before exposure; after exposure, attrition is preserved and reported rather than silently replaced.

Gold labels and sealed cases require two independent raters plus a resolver. Raw ratings, disagreements, exclusions, and agreement statistics are frozen before consensus. The scorer consumes the frozen gold artifact and verifies its hash and custody; it fails closed when they are missing. Consent materials cover random assignment, intentionally noisy views, proposed incomplete disclosure, debriefing, withdrawal cutoff, retention and deletion, privacy-controller and complaint-route placeholders, compensation, confidentiality, and publication choices. The incomplete-disclosure proposal must be authorized or removed through independent ethics determination; the draft itself does not authorize it. HHS guidance is used only as a conservative informed-consent reference, not as support for the incomplete-disclosure mechanics or as a claim that a particular jurisdiction or regulation applies [18]. An embargoed OSF preregistration draft is prepared locally, but no registration may be created before the protocol, ethics posture, and operator approval are settled [19].

The study is not run. The current reviewer package records 0 external reviewer responses, 0 qualified unique reviewers, false custody clearance, and false promotion. The synthetic return-path verifier records 23 synthetic return-path scenarios with 0 failed scenarios. Those scenarios exercise plumbing; they do not create reviewer evidence.

The launch gate remains hard:

- three qualified reviewers for the blinded bakeoff, or six distinct qualified reviewers for the exploratory pilot;
- one qualified reviewer per slot, with no reviewer ID reuse;
- role coverage across MCP/tool maintainer, platform engineer, and security/release governance perspectives;
- clean returned-file custody, digest echoes, and no private-map leaks;

- a pre-outreach frozen two-rater gold artifact with resolver rules and verified custody;
- declared accuracy, false-positive, and false-negative metrics on gold-scored cases, without relabeling decision movement as accuracy;
- substitute-pressure notes manually reviewed instead of hidden.

Recruitment is time-boxed to 30 days. If the quota is not feasible, the protocol records the funnel and failure, stops randomized allocation, and pivots to independent sealed-case adjudication plus descriptive expert review. Partial packets remain partial evidence. They are not renamed validation.

9 Sealed evaluation boundary

The sealed-evaluation layer is infrastructure, not a result. The repository freezes 10 author-selected, keyword-discovered candidate records, of which 8 are effective descriptor-bearing cases, and 0 scored sealed cases. It also records 9 reconstructed source-static descriptor pairs and 27 frozen pre-label model outputs. The mismatch between 10 candidates and 8 effective cases is preserved in every claim surface. These rows keep later labels from silently tuning the policy, but they are not independently sampled benchmark metrics and cannot estimate ecosystem false-positive or false-negative rates.

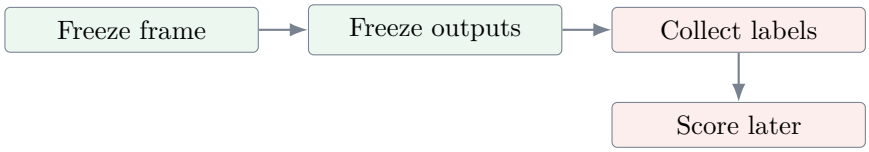


Figure 2: Sealed-evaluation boundary. The autonomous work freezes inputs and outputs before labels. It does not score benchmark performance.

Historical heldout fixtures remain regression data, and the scored sealed count stays at zero until independent labels exist. Adjudicators cannot serve as randomized reviewers or carrier maintainers. A later sample must use a predeclared frame that does not select candidates through policy-keyword hits alone; strata, random seed, exclusions, and descriptor-bearing eligibility must be frozen before label access.

10 Implementation and reproducibility

The reference implementation uses dependency-free Python and a CLI that works from either a source tree or an installed package. Evidence commands require an explicit fixture path or corpus ID. A source checkout can select both corpora. An installed wheel or source distribution exposes only `public-reproduction-53`; asking for `private-canonical-65` fails instead of falling back to public bytes.

Capture defaults to MCP 2025-11-25, also supports 2025-06-18, and rejects unknown requested or negotiated versions. Normalization retains current standard fields including `icons`, `execution`, `\_meta`,

Apps SDK security schemes, UI resource URIs, and OpenAI output-template metadata. Unknown extension fields are preserved rather than silently discarded.

The release verifier is the authoritative local gate. It checks tests, generated-report identity, public-surface wording, configured carriers, oasdiff evidence, SARIF structure, package build, wheel and source-distribution installs, exact artifact redistribution, active-study visibility, and clean tracked-tree behavior. Paper freshness is bound to source and PDF hashes rather than filesystem modification times. The source distribution promises a narrow, self-contained package surface; it no longer pretends to carry or test the private research repository.

The exact public export is built from an allowlist and records byte hashes, toolchain versions, and excluded private categories. Fresh extraction must reproduce every claim retained by the public paper. The private coordinator tree remains the canonical research surface but is not the publication unit.

11 Threats to validity

Curated corpus. The corpus was iterated during development. It is useful for regression and packet design, not for prevalence, precision, recall, or benchmark claims.

Public source-grounding gap. All 53 public-corpus records, including all 22 holds, are project-authored synthetic. The public corpus therefore supports policy regression and packaging checks but no claim about real-world positive or quiet-case behavior.

Descriptor trust. MCP and Apps SDK annotations are hints. Servers still need real authorization and runtime controls. Agent Tool Contract Drift cannot infer those controls from descriptors.

Heuristic labels. Several labels depend on names, descriptions, and schema field names. That is appropriate for a review prompt but not for a safety proof.

Substitute pressure. Configured tools already absorb the current corpus. This may mean the best future artifact is a policy plus carrier, not a standalone tool.

Reviewer absence. The main research question is whether reviewers find the labels useful beyond raw and configured views. That question is unanswered until external reviewers return packets.

Gold-label absence. Curated expected labels are author-produced regression targets. They are not independent truth. The gold and sealed protocols cannot produce scored evidence until two independent raters and a resolver complete them.

Study feasibility and ethics. A six-person specialized pilot may be infeasible, and compensation, privacy-controller details, jurisdiction, and independent ethics determination are unresolved. The 30-day fallback limits waiting; it does not cure those gaps.

No live code-scanning evidence. SARIF output passes a local structural preflight, but no GitHub code-scanning upload or alert rendering is verified.

12 Release posture

At this evidence snapshot, the artifact is a pre-review research package and local public-validation candidate. Its canonical coordinator workspace remains private. Public recruitment copy may be prepared, but screening, assignments, packets, frozen outputs, responses, identity and custody maps, gold labels, and adjudication remain private until scoring. A machine gate blocks publication if outreach has begun unless the study is explicitly invalidated and reseeded under the restart protocol.

Acceptable public-language draft:

> Agent Tool Contract Drift is a pre-review reapproval vocabulary and evaluation harness for agent-facing tool descriptor changes. Its public 53-case corpus reproduces 25 local policy findings; external usefulness is not yet established.

Do not call it a standard, validated benchmark, security scanner, production tool, or proof that generic diff tools cannot solve the problem. Do not imply endorsement by MCP, OpenAI, GitHub, Spectral, or oasdiff maintainers. The evidence snapshot used for this manuscript contains no DOI, OSF registration, preprint, live SARIF upload, or community response; later publication mechanics do not retroactively become validation evidence.

The intended sequence is: exact private remote and CI verification; embargoed preregistration only after independent ethics determination and approval; the time-boxed reviewer/adjudicator attempt; scoring and pivot decision; deterministic public export; GitHub prerelease; archival deposit and DOI; paper or preprint; MCP community scrutiny through the project's documented process [6]; Show HN only when the artifact is runnable; and LinkedIn last. GitHub and Zenodo mechanics are prepared from their official release and archive guidance [20, 21]. Every external step requires an explicit operator decision. Stars, impressions, downloads, and ranking are launch telemetry, not research evidence.

13 Conclusion

The practical output is a vocabulary for deciding when a tool descriptor needs renewed approval, plus the machinery needed to challenge it. The 53-case public corpus is a self-contained, locally verified reproduction target and the separate 65-case private corpus is accounted for, but neither is an independent benchmark. Correcting the MCP defaults reduced the finding count. Carrier parity removed the strongest argument for a novel standalone detector. Both negative results improve the work.

The next evidence must come from outside the author-controlled regression loop: independent labels, reviewer decisions, public reproductions, new descriptor pairs, and judgments about the right carrier. A policy document or oasdiff/Spectral integration may be the right endpoint. If raw diffs are enough, or if the provenance gap cannot be closed, the standalone project should end.

Disclosure

The author writes as an independent researcher. All views, judgments, and conclusions are the author's own and do not represent any employer, client, vendor, protocol maintainer, standards body, alliance, or cited project. The work does not use employer or client materials, proprietary templates, internal tools, confidential information, non-public business information, or employer-derived intellectual property. Third-party projects and products appear only as public-source technical context; citation does not imply endorsement, sponsorship, affiliation, or a client relationship.

The author may develop open-source or commercial tooling and services related to agent-tool assurance. This manuscript is a non-commercial research artifact, not an offer of certification, a compliance guarantee, or a claim that any system conforms. The author declares no competing interests beyond that prospective commercial interest.

A Claim boundary checklist

- Counts in this paper are local regression-harness counts.
- Reviewer exploratory-pilot machinery is pre-send infrastructure.
- Sealed-evaluation machinery is pre-label infrastructure.
- Source-full static replay is not runtime MCP output.
- SARIF preflight is not live code-scanning ingestion.
- Configured carrier parity demotes standalone-tool novelty and narrows the contribution to vocabulary, provenance, evaluation, and carrier choice.
- The 53-case public corpus has a separate manifest identity, retains 28 project-authored synthetic records from the private corpus byte-for-byte, adds 25 new controls, is not a private-corpus subset, and contains 0 source-derived descriptor bytes.

B Primary local artifacts

- `policy/tool-contract-drift-v1.json`: implementation-neutral policy definition.
- `tool_contract_drift/policy/tool-contract-drift-v1.json`: byte-matched installable policy copy.
- `tool_contract_drift/data/release_contract.json`: public corpus identity, composition hashes, expected counts, and toolchain pins.
- `tool_contract_drift/data/source_metadata_inventory.json`: metadata-only disclosure for the private-source boundary; not descriptor bytes or permission.
- `reports/current_linter_report.md`: human-readable result for the exact public corpus.

- `reports/current_linter_report.sarif`: machine-readable result for the exact public corpus.
- `paper/build_identity.json`: source-to-PDF byte binding.
- `paper/reference_audit.md`: citation identity and liveness audit.

The private corpus manifest, source-replay reports, assignment maps, gold scaffolding, reviewer packets, and sealed-evaluation coordinator records are intentionally omitted from the public distribution. Their disclosed counts are private-coordinator evidence, not claims that the public package reproduces those private bytes.

References

[1] Model Context Protocol Contributors. *Server tools specification*. Revision 2025-11-25. https://modelcontextprotocol.io/specification/2025-11-25/server/tools

[2] Model Context Protocol Contributors. *Schema reference: Tool and ToolAnnotations*. Revision 2025-11-25. https://modelcontextprotocol.io/specification/2025-11-25/schema

[3] Ola Hungerford, Sam Morrow, and Luca Chang. *Tool Annotations as Risk Vocabulary: What Hints Can and Can't Do*. Model Context Protocol Blog, 2026-03-16. https://blog.modelcontextprotocol.io/posts/2026-03-16-tool-annotations/

[4] OpenAI. *Apps SDK: Plan tools*. Accessed 2026-07-16. https://developers.openai.com/apps-sdk/plan/tools

[5] OpenAI. *Apps SDK reference*. Accessed 2026-07-16. https://developers.openai.com/apps-sdk/reference

[6] Model Context Protocol Contributors. *Specification Enhancement Proposal Guidelines*. Accessed 2026-07-16. https://modelcontextprotocol.io/community/sep-guidelines

[7] OpenAPI Initiative. *OpenAPI Specification, Version 3.2.0*. 2025. https://spec.openapis.org/oas/v3.2.0.html

[8] Austin Wright, Henry Andrews, Ben Hutton, and Greg Dennis. *JSON Schema: A Media Type for Describing JSON Documents*. IETF Internet-Draft, June 2022; JSON Schema dialect 2020-12. https://json-schema.org/draft/2020-12/json-schema-core

[9] Austin Wright, Henry Andrews, and Ben Hutton. *JSON Schema Validation: A Vocabulary for Structural Validation of JSON*. IETF Internet-Draft, June 2022; JSON Schema dialect 2020-12. https://json-schema.org/draft/2020-12/json-schema-validation

[10] GitHub Docs. *SARIF support for code scanning*. Accessed 2026-07-16. https://docs.github.com/en/code-security/reference/code-scanning/sarif-files/sarif-support

[11] Michael C. Fanning and Laurence J. Golding, eds. *Static Analysis Results Interchange Format (SARIF) Version 2.1.0 Plus Errata 01*. OASIS Standard incorporating Approved Errata, 2023. https://docs.oasis-open.org/sarif/sarif/v2.1.0/sarif-v2.1.0.html

[12] oasdiff contributors. *oasdiff: OpenAPI diff and breaking-change checker*. Version 1.23.0 source repository, accessed 2026-07-16. https://github.com/oasdiff/oasdiff

[13] Stoplight. *Spectral: JSON/YAML/OpenAPI linting toolkit*. Accessed 2026-07-16. https://github.com/stoplightio/spectral

[14] Paul Ralph et al. *Empirical Standards for Software Engineering Research*. arXiv:2010.03525v2, 2021. DOI: 10.48550/arXiv.2010.03525.

[15] ACM SIGSOFT. *Empirical Standards: Experiments with Human Participants*. Living standard, accessed 2026-07-16. https://www2.sigsoft.org/EmpiricalStandards/docs/standards

[16] Sandra M. Eldridge, Claire L. Chan, Michael J. Campbell, Christine M. Bond, Sally Hopewell, Lehana Thabane, and Gillian A. Lancaster. *CONSORT 2010 Statement: Extension to Randomised Pilot and Feasibility Trials*. Pilot and Feasibility Studies 2:64, 2016. DOI: 10.1186/s40814-016-0105-8.

[17] Robert L. Glass. *Pilot Studies: What, Why and How*. Journal of Systems and Software 36(1):85–97, 1997. DOI: 10.1016/0164-1212(95)00197-2.

[18] U.S. Department of Health and Human Services, Office for Human Research Protections. *Informed Consent FAQs*. Accessed 2026-07-16. https://www.hhs.gov/ohrp/regulations-and-policy/guidance/faq/informed-consent/index.html

[19] Center for Open Science. *OSF Registrations*. Accessed 2026-07-16. https://help.osf.io/article/330-welcome-to-registrations

[20] GitHub Docs. *Managing releases in a repository*. Accessed 2026-07-16. https://docs.github.com/en/repositories/releasing-projects-on-github/managing-releases-in-a-repository

[21] Zenodo. *GitHub integration and software archiving*. Accessed 2026-07-16. https://help.zenodo.org/docs/github/

[22] Zhiqiang Wang, Yichao Gao, Yanting Wang, Suyuan Liu, Haifeng Sun, Haoran Cheng, Guanquan Shi, Haohua Du, and Xiangyang Li. *MCPTox: A Benchmark for Tool Poisoning Attack on Real-World MCP Servers*. arXiv:2508.14925, 2025. DOI: 10.48550/arXiv.2508.14925.

[23] Yixuan Yang, Cuifeng Gao, Daoyuan Wu, Yufan Chen, Yingjiu Li, and Shuai Wang. *MCPSecBench: A Systematic Security Benchmark and Playground for Testing Model Context Protocols*. arXiv:2508.13220v3, 2026. DOI: 10.48550/arXiv.2508.13220.

[24] Hao Song, Yiming Shen, Wenxuan Luo, Leixin Guo, Ting Chen, Jiashui Wang, Beibei Li, Xiaosong Zhang, and Jiachi Chen. *Beyond the Protocol: Unveiling Attack Vectors in the Model Context Protocol (MCP) Ecosystem*. arXiv:2506.02040v4, 2025. DOI: 10.48550/arXiv.2506.02040.

[25] Manish Bhatt, Vineeth Sai Narajala, and Idan Habler. *ETDI: Mitigating Tool Squatting and Rug Pull Attacks in Model Context Protocol by Using OAuth-Enhanced Tool Definitions and Policy-Based Access Control*. arXiv:2506.01333, 2025. DOI: 10.48550/arXiv.2506.01333.

[26] Luca Beurer-Kellner and Marc Fischer. *Introducing MCP-Scan: Protecting MCP with Invariant*. Invariant Labs, 2025-04-11. Source repository now maintained as Snyk Agent Scan. https://invariantlabs.ai/blog/introducing-mcp-scan; https://github.com/snyk/agent-scan

[27] Microsoft Agent Governance Toolkit team. *MCP Security Gateway—Version 1.0*. Draft specification, 2025-07-28. https://microsoft.github.io/agent-governance-toolkit/specs/MCP-SECURITY-GATEWAY-1.0/